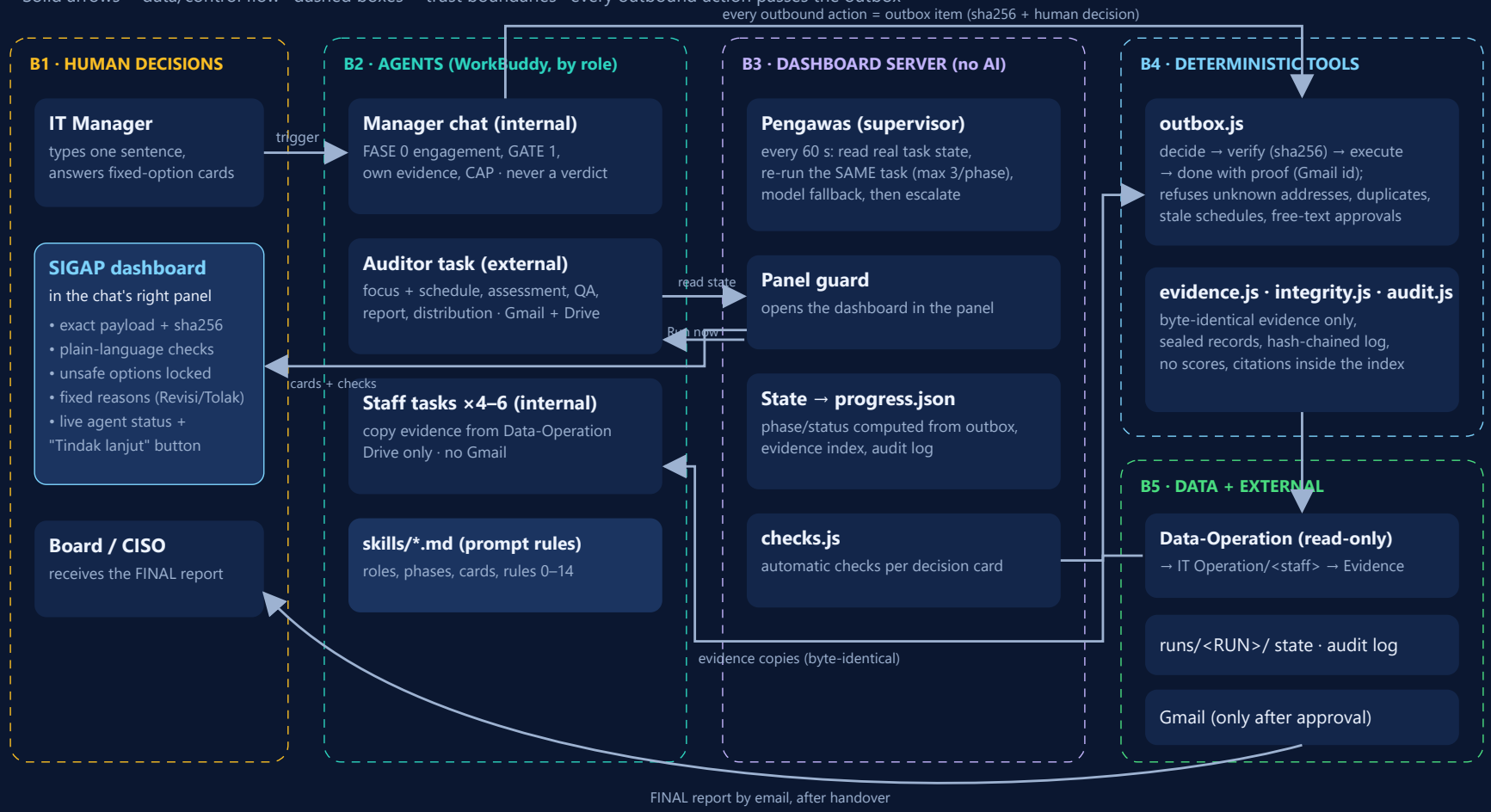
SIGAP — *architecture*

Components and five trust boundaries · v5.4 · ISO 27001 readiness self-assessment on WorkBuddy (Tencent "AI CAN DO IT" 2026, Challenge B)

SIGAP v5.4 — components and trust boundaries

Solid arrows = data/control flow · dashed boxes = trust boundaries · every outbound action passes the outbox



Components and *roles*

Agents propose, code verifies, a human decides

COMPONENT	WHERE	ROLE
Manager chat	WorkBuddy conversation `ISO270001-NN Manager`	IT Manager (internal auditee): opens the run, GATE 1, releases its own evidence, accepts the report, owns the CAP. Never assesses.
Auditor task	WorkBuddy scheduled task · Gmail + Drive	External auditor: proposes 3–5 focus items and a schedule, checks completeness, assesses, QA, publishes and distributes the report.
Staff tasks	WorkBuddy scheduled tasks · Drive only	Copy documents byte-identical from Data-Operation into their own folder; request a release per file. No Gmail.
Skills	`skills/*/SKILL.md`	Prompt layer: roles, nine phases FASE 0–8, card catalogue, rules 0–14. Loaded by the trigger `mulai audit ISO 27001`.
SIGAP dashboard	`progress-dashboard/` · `127.0.0.1:4173`	The single place for human decisions; opens itself in the Manager chat's right panel; plain-language checks lock unsafe options; fixed reasons for Revisi/Tolak; live agent status.
Pengawas	inside the dashboard server (no AI)	Every 60 s reads the real WorkBuddy task state, re-runs the SAME stalled task (max 3 per phase), switches model when saturated, then escalates to a human.
Deterministic tools	`tools/` (Node.js)	`outbox.js` sealed outbound items · `evidence.js` byte-identical evidence, no scores · `integrity.js` / `audit.js` sealed records, hash-chained log.

One decision, *end to end*

How an outbound action (email, invitation, task, release, report) moves through the boundaries

1. **Agent creates an outbox item**
   exact payload (recipients, time, body) + sha256 — nothing is sent yet
2. **Dashboard shows it with automatic checks**
   contacts only · no duplicate · schedule in the future · no internal text · unsafe options locked
3. **Human decides**
   fixed option; Revisi/Tolak need a fixed reason; free text never approves
4. `outbox.js verify`
   payload still matches the approved sha256, item not stale
5. **Execute**
   WorkBuddy connector (Gmail) or task creation
6. `done` **with proof**
   e.g. a Gmail message id — without it the item is not "sent"
7. **Hash-chained audit log + decision note**
   who decided, what, when, proof

Rules in code, not only in prompts

Agents broke prompt rules in testing (run 11: the Manager edited its own guard tool). Cost: more tooling; scope/automation rules are still partly prompt-level.

Pengawas is server logic, not another agent

Stalls came from the platform (model saturation, 429); recurring tasks run at most hourly. Cost: needs WorkBuddy's local debug port.

Dashboard for task-made items

Cards were not rendered inside task sessions (run 08) — the dashboard lives in the Manager chat's right panel.

Conformity statuses, no scores

Conform · Minor NC · Major NC · OFI · N/A — a number looks more certain than the evidence.

Evidence only from Data-Operation, byte-identical

Missing evidence becomes a clarification card ("Belum tersedia"), never a guess.

Separation of duties

The external Auditor issues and sends; the Manager never assesses.